

AdvocateAuroraHealth

Title: AAH Network Security		Document Number: 2552
Document Type: ☒ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 06/30/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 06/30/2024
		Effective Date: 06/30/2021
Scope: ☒ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

The purpose of this policy is to secure Advocate Aurora Health, Inc. (Advocate Aurora) networks and network devices. This policy will outline the requirements for information systems, network hardware and communication services.

II. SCOPE

This policy applies to Advocate Aurora Health, Inc. (Advocate Aurora) and any entity or facility owned and controlled by Advocate Aurora. This policy also applies to third parties and non-employed Team Members accessing Advocate Aurora Information and Information Resources.

III. DEFINITIONS/ABBREVIATIONS

Antivirus: Software that is designed to detect, contain and eradicate computer viruses.

Advocate Aurora Team Member: anyone employed by Advocate Aurora Health who provides services on behalf of Advocate Aurora. All Advocate Aurora Team Members are expected to abide by Advocate Aurora policies and procedures. All Advocate Aurora Team Members are eligible to receive access to internal Advocate Aurora systems, as required.

Advocate Aurora Information: All information that is owned by Advocate Aurora or owned by third parties but provided to Advocate Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a third party (e.g., a third-party service provider and/or its subcontractors).

Advocate Aurora Information Resources: Any media, software, hardware or other technology that supports the use, access, processing, storage or transmission of Advocate Aurora Information.

Business Owner: A team member who sponsors a solution's creation or who has a business need for the solution.

Console Ports: A type of out-of-band management that require a physical cable/serial connection to access.

Content Filtering: The use of a program to screen and exclude access or availability of web pages or other traffic deemed objectionable.

Restricted Access Confidential Information: includes any Advocate Aurora Information that would be likely to result in liability or other harm (including reputational harm) to Advocate Aurora if disclosed without authorization.

Legally-Restricted Confidential Information: includes any Advocate Aurora Information that is subject to laws or regulations related to its confidentiality, privacy, or security. Unauthorized disclosure of this information poses a significant risk and may result in criminal or civil fines, liabilities and breach notification obligations for Advocate Aurora.

Encryption: The process of converting information either in storage or in transit into an unintelligible form except to holders of a specific cryptographic key. Use of encryption protects information between the encryption process and the decryption process (the inverse of encryption) against unauthorized disclosure.

Out-of-Band Management: The use of management interfaces (or serial ports) to manage servers and networking equipment that involves an alternate and dedicated connection separate from the actual network that the system runs on.

HIT Owner: A team member who is responsible for the information technology aspects (e.g. implementation, maintenance, etc.) of a solution.

Host Based Firewall: Software which blocks unauthorized access to a system while permitting outward communication.

Host Based Intrusion Prevention System (HIPS): Software which monitors for suspicious activity by monitoring the behavior of code.

Multihoming: The practice of connecting a host or computer with more than one network interface to multiple networks.

Patch: A piece of software that is designed to update, fix, or improve another piece of software, supporting data, or operating system.

Software: Computer programs (code), procedures, documentation and data pertaining to the operation of a computer system. For this policy, "software" refers to all software which accesses or is used to access Advocate Aurora Information and Information Resources.

Shared Workstations: Desktops or laptops which are shared between multiple Team Members and may not require a Team Member to sign into the operating system with his or her unique username and password.

Simple Network Management Protocol (SNMP): An application-layer protocol used to manage and monitor network devices and their functions.

IV. POLICY

- A. The AAH HIT Network Security team will implement network infrastructure security controls and security management systems for networks to ensure the protection of equipment and attached information systems, including:
 - 1. Stored information;
 - 2. Network infrastructure;
 - 3. Network configuration information, including device configuration, access control definitions, routing information, passwords and cryptographic keys;
 - 4. Network management information;
 - 5. Network pathways and routes;
 - 6. Network resources such as bandwidth;
 - 7. Network security boundaries and perimeters;
 - 8. Information system interfaces to networks; and,
 - 9. Security infrastructure
- B. Secured Path
 - 1. Legally-Restricted Confidential Information, as defined in the Information Classification Policy, must be transmitted using a secured path. Secured paths for information transmission must use adequate security controls such as data, message, or session encryption (e.g., SSH, SSL or VPN tunnels) and/or other methods to detect tampering, as determined by Network Security and Enterprise Network Services.
 - 2. Network Security and the Enterprise Network Services Teams will work with the HIT Owner of an Information Resource to establish a secure path to transmit information that includes adequate security controls, such as data, message, or session encryption (e.g., SSH, SSL or VPN tunnels); and/or, other methods to detect tampering when sending Advocate Aurora Information within the network.
 - 3. Transmission of any Legally-Restricted Confidential Information by Advocate Aurora Information Resources must use a secure path within or outside the network, where technically feasible.
 - 4. External out-of-band management is managed by the HIT Network Security Team and the Enterprise Network Services Team. This includes network equipment as well as end-user devices. If a cellular or data modem is required for a specific business purpose,

the need must be documented, approved and reviewed periodically for appropriateness.

C. Segregation of Services

1. The Network Security Team must segregate services, information systems and users to support business requirements for information system connectivity and access control based on the principles of least privilege, management of risk and segregation of duties.
2. Network traffic flow control points such as firewalls, routers, switches, security gateways, VPN gateways or proxy servers must be implemented at multiple points throughout the network to provide the required level of control. Factors to consider include:
 - a) The information classification;
 - b) The trustworthiness of the network, based on the amount of uncontrolled malicious traffic present, the level of device identification and authentication in the networks, and sensitivity to eavesdropping (e.g., the Internet is a less trusted network than a controlled server network zone);
 - c) Transparency, usability, and management costs of network segregation technologies; and,
 - d) The availability of compensating controls for detection, prevention and correction of malicious network traffic and unauthorized access attempts.

D. Logical access

1. Access to network devices must be limited by access control so that the equipment is only accessible by an authorized user. Logs must be reviewed by the Security Operations Center for suspicious behavior.
2. Access to configuration backups must be restricted to authorized personnel only.
3. All external connections to the AAH network must be protected by layered security controls configured for least privileges.
4. Access control to network devices must be reviewed at least annually or as needed.
5. Centralized user-level authentication must be used to authenticate all users making changes to network devices where technology permits.
6. All changes must be logged using the central user-level authentication where technology permits.
7. Multihoming between secured and non-secured networks is prohibited unless approved by network security. Devices are not allowed to bridge the internal and public network.

E. Wireless access

1. Wireless Local Area Network access points must be authorized by the Enterprise Network Services Team. Controls should include:
 - a) User and device network access is controlled by HIT authentication services (e.g., Active Directory, etc.);
 - b) The use of strong encryption keys and passwords;
 - c) Segregation of wireless networks from wired networks.
2. The use of rogue access points or unauthorized extension of the networks is prohibited.
3. Signal jamming and radio interference of the AAH network is prohibited.
4. Guest network
 - a) The Guest Network must be configured such that a peer cannot see another peer's activities.
 - b) Team Members wishing to connect to the internet on a non-AAH owned device must only do so on the guest network.
 - c) Content filtering such as Intrusion Prevention System (IPS), anti-virus, threat detection; is used on guest networks.
 - d) Must not be used production services by tenants or other guests (i.e. guest shops) (for patients or transient visitors, not for production/

F. Network Management Access

1. Management interfaces must not be configured on the default VLAN setting (e.g. VLAN 1) where feasible.
2. Unencrypted protocols must not be used in network management.
3. Access to management interface must use unique authentication and encryption protocols.
4. Console ports used for device management must be secured by a username/password at a minimum.
5. Default public/private SNMP community strings must be changed.
 - a) Private SNMP should never be shared with anyone outside of Advocate Aurora.
6. Patches, mitigations, or fixes for identified vulnerabilities must be mitigated according to the Vulnerability Management Standard.
7. Network management interfaces must adhere to RFC 1918 for private IP addressing where possible.

G. Network Access Control

1. Security gateways will be considered for network access control points. Gateways will be used to validate source and destination addresses when proxy servers or network address translation are used with secondary identity verification techniques (e.g., user identifier and password, digital certificates).

- H. Control of Routing Information
 - 1. The Enterprise Network Services Team must implement network routing protocols leveraging best practice security controls to prevent unauthorized access to, or tampering of, network routing information (e.g., through use of encryption, authenticated routing protocols, access control lists).
- I. Security gateways and firewalls
 - 1. A firewall must be used between internal and external networks (3rd party networks and the Internet).
 - 2. HIT Network Security shall conduct a periodic review of firewall rules and usage logs at least annually.
 - 3. The IPS configuration will be reviewed monthly or upon changes to the configuration.
 - 4. Networks will use network segmentation to promote the principle of least privilege.
 - 5. Reverse proxies and Business to Business Virtual Private Networks (B2B VPNs) need to be reviewed and approved by HIT Security as defined in the Remote Access Security Policy.
- J. Logging, Monitoring and Detection
 - 1. AAH reserves the right to routinely monitor, log and record any and all use of its network resources and facilities.
 - 2. To facilitate monitoring, response and investigation, all network devices must enable and forward logs to a Security Incident and Event Management (SIEM) tool, or other centralized log management service, as capacity allows.
 - a) Network devices must be regularly monitored for their ability to be reached by a centralized monitoring system.
 - b) Any logs must be confidentially provided to the appropriate information security officer upon written request.
 - c) Transmissions of network logs to or from entities external to the secure site, including to other secure sites using networks or any communications outside the AAH network are subject to review and are required to be supported by business need.
 - 3. Vulnerability scanning & quarantines
 - a) HIT Security will perform security checks which may include vulnerability scans and penetration testing. HIT Security will work with HIT and Business Owners to make sure scans do not interfere with business operations or patient care.
 - b) All devices on the network will be scanned or tested for vulnerabilities by HIT Security using the centrally managed vulnerability scanners.

- c) All data gathered from the vulnerability scan and quarantine processes are regarded as AAH Legally restricted confidential data.
- d) Notifications of quarantine or blocking:
 - (1) The Enterprise Network Services Team or Network Security Team will maintain accurate registration information of all devices on the network.
 - (2) Unless the network may be harmed without immediate quarantine or blocking of compromised computers, the Network Administrator must notify system administrators of vulnerabilities found by the vulnerability scanner before the systems are blocked or placed into quarantine.
 - (3) If immediate quarantine or blocking is necessary to avoid harm to the network, the Network Administrator must notify administrators of affected systems in a timely manner.

K. Configuration Control, Change Review and Backup

- 1. To maintain the integrity of networks, The Enterprise Network Services Team must manage and control changes to network device configuration information such as configuration data, access control definitions, routing information and passwords. Network device configuration data must be protected from unauthorized access, modification, misuse or loss using controls such as:
 - a) Encryption;
 - b) Access controls and multi-factor authentication;
 - c) Monitoring of access;
 - d) Configuration change logs;
 - e) Configuration baselines protected by cryptographic checksums; and,
 - f) Regular backups.
- 2. Change Review
 - a) All changes to the AAH network and network devices must follow the appropriate change controls, as defined in the Change Management Standard. Requests can be initiated by users or HIT Security.
 - b) Any changes involving risk to the AAH network must be reviewed by IT Security/Compliance and the effected groups.
- 3. Configuration Backups
 - a) The configuration of network components must be backed up prior to any changes.
 - b) Changes to the configuration must be auditable.

- c) An audit of network configurations must be conducted on a periodic basis.

V. PROCEDURE

Not Applicable

VI. CROSS REFERENCES

- A. AAH Vulnerability Management Standard
- B. AAH Information Classification Policy
- C. AAH Remote Access Security Policy
- D. AAH HIT Change Management Standard

VII. RESOURCES AND REFERENCES

HIPAA	164.310(b) 164.310(c)
NIST-800-53 rev. 4	AT-1, AT-2, AT-3, AT-4, SA-11, SA-16, PM-13, PM-14, PM-15, AC-4, CA-3, CA-7, CA-9, CM-, CM-3, CM-5, CM-6, CM-8, MA-4, SC-24, SI-4, AC-17, AC-20, SA-9, SC-7
PCI DSS 3.2.1	1.1, 1.2, 1.2.2, 1.2.3, 1.3.7, 2.1, 6.1, 6.2, 7.1, 7.2, 8.2.1, 10.1, 10.5, 10.6, 11.1, 11.4.
HITRUST CSF v.8.1	01.Y, 09.AB, 09.J, 09.O, 10.M, 06.H, 09.M, 01.Q, 09.AB, 07.A, 07.D, 01.X
CIS Critical Security Controls	#9 Limitation and control of network ports #11 Secure configurations for network devices #12 Boundary defense #15 Wireless access control
RFC 1918	

VIII. ATTACHMENTS

Not Applicable